Sécurité du Code et du Web – 4IRC CPE Lyon 2026-2027

Projet de synthèse : Investigation Forensic web

Lundi 9 novembre 2026, vous recevez un e-mail **(e-mail initial en Annexe 1)**.

Il provient d'une certaine Élodie Marchand qui demande d'urgence à votre équipe CERT (Computer Emergency Response Team) une assistance cyber pour sa plateforme **hackbnb.fr**. Vous prenez connaissance de l'e-mail et décidez de la joindre directement par téléphone pour obtenir plus d'informations.

L'entreprise HackBNB a reçu un e-mail anonyme le samedi 7 novembre revendiquant une compromission de leur plateforme, et souhaite déterminer si celle-ci est avérée **(e-mail anonyme en Annexe 2)**. Si c'est le cas, ils souhaitent identifier précisément les vulnérabilités exploitées et les données potentiellement exfiltrées, puis obtenir de l'aide pour corriger rapidement les vulnérabilités pour éviter un nouvel incident.

La CEO Élodie Marchand vous fournit le contact téléphonique de Karim Lefèvre, le responsable technique de la plateforme, afin d'échanger plus en détails sur les éléments techniques **(échange en Annexe 3)**.

Vous envoyez un devis pour l'intervention qui est renvoyé signé quelques heures plus tard.

Vous contactez vos analystes CTI (Cyber Threat Intelligence) afin d'investiguer sur les forums du darkweb et ceux-ci vous informent rapidement d'une mention de la plateforme HackBNB **(Annexe 4)**.

En parallèle, vous recevez un e-mail du responsable technique de la plateforme contenant les accès au repository GitHub du projet, les logs Apache du jour de l'attaque, l'adresse de leur plateforme de pré-production, ainsi qu'un rapport de test de pénétration de leur plateforme **(rapport en Annexe 5)**.

> Repository GitHub du projet : https://github.com/pierreavn/project-hackbnb-sources
> Plateforme de pré-production (identique à la production) : https://hackbnb.dashbox.cloud

Vous avez rendez-vous dans quelques jours (le **lundi 23 novembre après-midi**) avec le client pour leur **présenter votre investigation et vos conclusions, ainsi que les correctifs** effectués dans le code-source pour remettre en ligne la plateforme au plus vite.

📂 **Au plus tard le soir de la soutenance (lundi 23 novembre 23:59)**, déposer :

- sur e-Campus :
  - les **slides de votre présentation orale**
  - une **synthèse technique destinée aux développeurs de la plateforme**, résumant les vulnérabilités et des captures d'écran pour prouver que vous avez réussi à exploiter ces vulnérabilités sur la pré-production
- sur GitHub :
  - le **code-source corrigé** par vos soins

GLHF !

Objectifs et Méthodologie d'investigation

L'objectif principal est de **déterminer de manière factuelle** (avec des preuves) s'il est possible d'affirmer ou non que **la plateforme hackbnb.fr a été compromise le 7 novembre 2026**. Ce genre de preuve en cybersécurité s'appelle un **IoC** (Indicator of Compromise → Indicateur de compromission).

Si la plateforme a été compromise, le second objectif est de déterminer la chronologie de l'attaque, les vulnérabilités exploitées dans l'application, le profil de l'attaquant, les données exfiltrées ainsi que les correctifs de sécurité mis en place dans le code-source pour éviter une nouvelle compromission.

L'échange sur votre investigation durera 25 minutes au total avec l'ensemble de l'équipe,
soit **10 à 15 minutes de présentation suivi d'un échange questions/réponses**, et devra présenter :

🔧 **La méthodologie d'investigation**
Outils utilisés lors de l'investigation et la répartition des tâches au sein de l'équipe.

🔓 **Les vulnérabilités de l'application**
Localisation précise dans le code-source des vulnérabilités évoquées dans le test d'intrusion, démonstration de leur difficulté d'exploitation et justification de leur impact.
- 👉 Étudiez le rapport de test d'intrusion en annexe et identifiez dans le code-source les vulnérabilités
- 👉 Exploitez sur la pré-production les vulnérabilités critiques pour justifier leur impact
- 👉 Pour la synthèse, vous pouvez si vous le souhaitez vous inspirer de : https://www.sans.org/white-papers/33343

🕒 **La chronologie de l'attaque**
Timeline qui mentionne avec précision (date et heures) les moments clés de l'attaque :
première connexion de l'attaquant, actions suspectes, exploitation des vulnérabilités, exfiltration des données, prise de contact de l'attaquant avec l'entreprise, publication des données exfiltrées, …
- 👉 Étudiez l'ensemble des annexes et analysez les logs Apache du jour de l'attaque avec Grafana

🥷 **Le profil de l'attaquant**
À minima : pseudonyme, adresse e-mail, adresse IP, navigateur web, système d'exploitation
- 👉 Étudiez les annexes en lien avec l'attaquant et analysez les logs Apache du jour de l'attaque

📦 **Les données exfiltrées par l'attaquant**
Quelles données (base de données, services externes, clés API, …) ont été exfiltrées par l'attaquant ? Indiquez pour chacune si c'est une supposition, ou si vous êtes certain avec une preuve (IoC) à l'appui.
- 👉 Étudiez les annexes en lien avec l'attaquant et analysez les logs Apache du jour de l'attaque
- 👉 Comparez-les avec les données trouvées sur l'environnement de pré-production

🖊️ **Les correctifs mis en place dans le code**
Explications synthétiques des correctifs que vous avez mis en place pour remédier aux vulnérabilités.
- 👉 Étudiez le rapport de test d'intrusion et corrigez les vulnérabilités en vous aidant des cours / TP

💡 **Vos recommandations**
Proposez des idées de mesures supplémentaires que le client pourrait mettre en place pour limiter les risques d'une future attaque de ce type, ou à minima pour pouvoir la détecter plus tôt.

Suggestion de répartition des tâches

- Étape 1 : Lecture ensemble des annexes
- Étape 2 :
    - 1 personne analyse les logs Apache pour déterminer la chronologie de l'attaque et le profil de l'attaquant (voir méthode ci-dessous)
    - 2 personnes recherchent dans le code les vulnérabilités mentionnées dans le rapport de test d'intrusion et tentent de les exploiter sur l'environnement de pré-production (rédaction de la synthèse technique au fur et à mesure pour ne rien oublier)
- Étape 3 :
    - Mise en commun des informations
- Étape 4 :
    - 1 personne synthétise la chronologie de l'attaque et le profil de l'attaquant
    - 2 personnes corrigent les vulnérabilités dans l'application et vérifient que les méthodes d'attaque utilisées (connues grâce aux logs Apache) ne fonctionnent plus
- Étape 5 :
    - Mise en commun des informations
    - Préparation commune de la présentation de l'investigation
    - Finalisation de la rédaction de la synthèse technique
- Étape 6 :
    - Dépôt du support de présentation et du rapport sur e-Campus
    - Dépôt du code-source corrigé sur GitHub

Analyse de logs Apache avec Grafana

Pour analyser les logs Apache du jour de l'attaque, clonez le dépôt GitHub ci-dessous :

https://github.com/pierreavn/project-logs-analysis

Téléchargez le fichier de logs Apache et placez-le à la racine du dépôt cloné
puis démarrez Grafana avec la commande :

```
docker compose up
```

Accédez à l'interface de Grafana à l'adresse http://localhost:3000 et utilisez les identifiants :
Email or username : **admin** Password : **admin**

Dans l'onglet **Connections**, cliquez sur **Add new connection** et recherchez **Loki**.
Cliquez sur **Add new data source** et saisissez comme connection URL : **http://loki:3100**
Cliquez sur **Save & test**

Dans l'onglet **Drilldown**, cliquez sur **Logs**.
En haut à droite, **sélectionnez la date de l'incident** (de 00:00 à 23:59) pour filtrer les logs.
En haut à gauche, choisir dans la barre de filtres **log_file = apache.log** et cliquez sur **Show logs**.

👉 Les logs sont importés progressivement dans la base de données Loki
(l'import peut prendre quelques minutes)

Annexe 1 : Premier e-mail de contact avec HackBNB

Demande urgente d'assistance cyber sur hackbnb.fr

Élodie Marchand <elodie.marchand@hackbnb.fr> 9 novembre 2026 à 07:12
À: CERT <contact@cert.fr>

Bonjour,

Je vous contacte concernant notre plateforme HackBNB (hackbnb.fr), un service en ligne permettant à des professionnels de la cybersécurité de trouver des lieux de séjour adaptés à leurs activités, dans un cadre légal et communautaire.

Le 7 novembre, un e-mail anonyme revendiquant une compromission de notre plateforme a été envoyé à notre adresse de contact. Malheureusement ce message est parti dans les spams et nous n'en avons pris connaissance que ce matin.

Nous n'avons pas encore identifié de dommages visibles sur nos services, nous sommes particulièrement inquiets pour la confidentialité des données de nos utilisateurs, qui incluent des profils sensibles du monde cyber.

Pouvez-vous me recontacter afin de déterminer si cette compromission est avérée, et si oui permettre d'identifier les vulnérabilités exploitées et les données potentiellement exfiltrées. Nous souhaiterions également être accompagnés pour corriger rapidement les vulnérabilités identifiées pour éviter un nouvel incident.

Je reste personnellement joignable par e-mail ou par téléphone au 06 ** ** ** **.

Merci par avance,

Cordialement,
Élodie Marchand
CEO – HackBNB
elodie.marchand@hackbnb.fr

Annexe 2 : E-mail réceptionné par HackBNB

Vulnerability reports from an ethical hacker

contact@hackb3ck.me 7 novembre 2026 à 23:51
À: contact@hackbnb.fr

Hello hackbnb.fr,

My name is hackb3ck, I am a bug bounty hunter and I found some critical vulnerabilities in your website.

Do you have a bug bounty program and do you offer rewards for ethical hackers like me ?

Thank you.

Best regards.

Annexe 3 : Entretien téléphonique avec le responsable technique

---

Retranscription de l'entretien téléphonique avec Karim Lefèvre
Karim Lefèvre – Responsable technique de la plateforme hackbnb.fr
Le 9 novembre 2026 à 08h45

CERT : Bonjour Karim, merci de prendre le temps pour cet échange. Vous pouvez nous expliquer ce qui vous a amené à nous contacter aujourd'hui ?

Karim : Bien sûr. Ce matin, en consultant nos mails, on a découvert par hasard un message qui était tombé dans les spams. Il date du 7 novembre au soir. C'était un message d'un hacker, qui prétend avoir trouvé des vulnérabilités critiques sur notre site.

CERT : D'accord. Qu'est-ce que disait exactement le mail ?

Karim : Il expliquait qu'il avait identifié plusieurs failles sur hackbnb.fr, et il nous demandait si on avait un programme de bug bounty ou si on proposait une récompense pour la divulgation. Mais comme l'e-mail était dans les spams, on ne l'a vu que ce matin… donc on n'a pas encore répondu.

CERT : Je vois. Vous pouvez m'en dire plus sur la plateforme elle-même ?

Karim : Oui bien sûr. HackBNB c'est un service en ligne qui permet à des professionnels de la cyber de trouver des lieux de séjour adaptés à leurs activités. Le concept repose sur une communauté légale et éthique, où les gens peuvent travailler dans des lieux accueillants pour le hacking éthique. Donc forcément, on a pas mal d'utilisateurs avec des profils sensibles dans le monde cyber… ce qui rend la situation encore plus préoccupante pour nous.

CERT : Quelles ont été vos premières réactions suite à la découverte du mail ? Vous avez déjà mis des mesures en place ?

Karim : Oui, dès qu'on a vu le mail ce matin, on a décidé de mettre le site complètement hors ligne. C'était la priorité, le temps d'y voir plus clair et d'éviter d'autres risques.

CERT : Très bien, c'était la bonne chose à faire. Vous pouvez détailler la stack technique de la plateforme ?

Karim : Bien sûr. Le site a été développé récemment par une petite équipe composée de deux développeurs juniors. La stack est composée d'un front en React, et d'un back en Flask, c'est du Python. On héberge tout chez OVH, sur un serveur classique avec Apache comme reverse-proxy.

CERT : D'accord. Est-ce que vous pouvez nous transmettre les logs Apache du 7 novembre, le jour supposé de l'attaque ?

Karim : Oui, pas de souci, je vous enverrai ça tout de suite après l'appel. Petite précision : on a modifié la configuration du serveur quelques jours avant l'attaque, pour empêcher Apache d'écrire sur le disque. C'était une mesure de durcissement qu'on avait prévue, et il se trouve que ça a probablement limité les dégâts. En tout cas, on n'a pas vu de fichier suspect déposé sur le disque.

CERT : Justement, est-ce que vous avez remarqué un comportement anormal sur l'application ?

Karim : Non, à ce stade rien d'anormal. Le site fonctionnait normalement jusqu'à ce qu'on le coupe ce matin. Pas d'erreurs, pas de comportements étranges côté utilisateur.

CERT : Quels services ou API externes utilisez-vous sur la plateforme ?

Karim : On utilise Stripe pour gérer les paiements de réservation, mais à part ça, aucun autre service.

CERT : Et vous savez où sont stockées les clés API de Stripe ?

Karim : Alors… elles étaient en dur dans le code au début, mais on a fait une grosse passe de nettoyage en début d'année pour les passer en variables d'environnement. Donc normalement elles ne sont plus accessibles dans le code source. Ça voudrait dire que même si l'attaquant a eu accès au code du serveur en production, il n'a pas dû avoir accès aux clés API. Mais bon, ça reste à confirmer, on préfère rester prudents.

CERT : Est-ce que les utilisateurs peuvent uploader des fichiers, ce qui pourrait mener à exécuter du code à distance ?

Karim : Non, aucune fonctionnalité d'upload côté utilisateur. Ils peuvent uniquement faire des réservations et consulter leurs réservations passées, rien d'autre.

CERT : OK super. Est-ce que vous pourriez nous mettre à disposition le code source de l'application, ainsi qu'une instance de pré-production identique à la production, pour qu'on puisse reproduire un éventuel chemin de compromission ?

Karim : Oui, absolument. Je peux vous donner accès à notre dépôt GitHub et on a une instance de préprod qu'on peut réactiver. Elle est identique à la prod.

CERT : Parfait. Écoutez, je pense qu'on a toutes les informations nécessaires pour démarrer. On va vous envoyer un devis rapidement. On peut mobiliser une équipe assez vite. L'objectif, c'est de déterminer l'étendue de la compromission, voir si des données sensibles ont été exfiltrées, et si oui, identifier les vulnérabilités et vous aider à les corriger.

Karim : Très bien. Et justement, on serait aussi intéressés par une prestation de correction des vulnérabilités dans le code. On est seulement deux développeurs, et clairement on manque de temps pour assurer tout ça correctement.

CERT : C'est noté, on inclura cette partie dans le devis. On va également faire une recherche sur les forums de fuite de données du darkweb, voir si cette attaque a déjà fait surface. Vous avez d'autres questions ou points à aborder ?

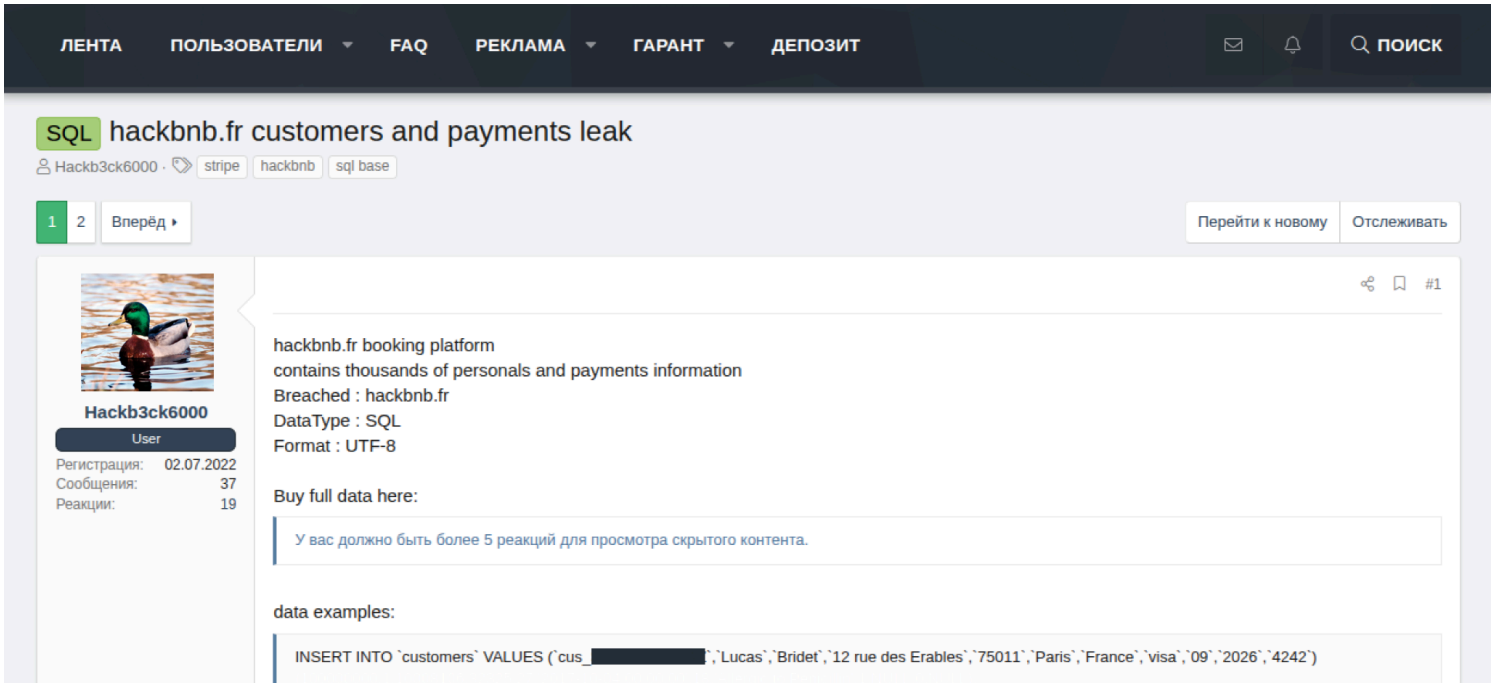
Karim : Non, de mon côté c'est tout bon… ah si j'allais oublier ! On a fait un test d'intrusion de l'application il y a quelques mois, mais faute de temps on n'a pas encore pu corriger ce qui avait été remonté. Je peux vous transmettre le rapport de cet audit ? Si ça peut vous aider.

CERT : Oui avec plaisir, ça va nous aider. Merci, on revient rapidement vers vous avec les prochaines étapes. Bonne fin de journée.

Karim : Merci pour votre réactivité, à bientôt.

Annexe 4 : Post identifié sur un forum du darkweb

Le post ci-dessous a été publié sur le forum le 9 novembre 2026 à 06h37
Capture d'écran réalisée le 9 novembre 2026 à 12h13



Annexe 5 : Rapport de Test d'Intrusion

Rapport de Test d'Intrusion

3 au 5 juin 2026 – hackbnb.fr

Note de confidentialité

Ce document contient des informations confidentielles. Il ne peut être diffusé qu'aux personnes ayant besoin d'en connaître pour corriger les vulnérabilités identifiées. La copie, reproduction ou transmission hors de ce cadre est interdite sans autorisation écrite.

Contexte de l'audit

HackBNB a mandaté l'entreprise d'audit pour évaluer la sécurité de son application web face aux attaques. Le périmètre considéré pour l'audit est le suivant :

hackbnb.fr

Le test d'intrusion a été mené en **boite grise**. Ce type d'audit permet d'évaluer les menaces engendrées par un utilisateur standard, ou un attaquant externe ayant élevé ses privilèges en tant qu'utilisateur standard.

L'audit s'est déroulé **du 3 au 5 juin 2026 inclus** depuis les adresses IP 18.25.133.0/29. Deux consultants ont travaillé sur cet audit pour une charge totale de 6 jours-hommes.

L'audit mené est non-destructif : il ne vise ni à menacer l'intégrité des données en place, ni à menacer le bon fonctionnement des services (pas de déni de service, notamment).

Structure de ce rapport

Ce rapport contient une synthèse dans laquelle sont décrits le niveau de sécurité global et les impacts métiers potentiels résultant des failles découvertes.

Afin de clarifier la lecture du présent rapport, l'échelle de classification des vulnérabilités que nous utilisons (ANSSI) est disponible en dernière page.

Synthèse des résultats de l'audit

Niveau de sécurité global

Au vu des résultats de cet audit, effectué du 3 au 5 juin 2026, le périmètre audité dans le contexte précisé présente un niveau de sécurité global **CRITIQUE**.

Cette évaluation se base sur différents facteurs, tels que la gravité des défauts de sécurité constatés, les risques que présente l'exploitation de ces défauts dans votre contexte, ainsi que l'expérience des auditeurs face à des périmètres similaires précédemment audités.

Défauts de sécurité constatés

Durant cet audit, **8 défauts de sécurité** ont été identifiés :

Critique : **4**	Majeur : **3**	Important : **0**	Mineur : **1**

L'évaluation de leur criticité est basée sur l'échelle de classification des vulnérabilités proposée par l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information), fournie dans les annexes.

ID	Libellé	Exploitation	Impact	Type
D1	Injection SQL sur la page d'accueil permettant de compromettre la base de données	Facile	Critique	A
D2	Lecture arbitraire (path traversal) sur le serveur via une route de récupération de fichiers	Facile	Critique	A
D3	Paramètre non-contrôlé sur une route des réservations permettant d'exploiter une vulnérabilité de type SSRF	Modérée	Critique	A
D4	Génération vulnérable de secrets permettant de confirmer une réservation sans procéder au paiement final	Modérée	Critique	A
D5	Exposition de l'adresse e-mail des hôtes dans les réponses API	Facile	Important	D
D6	Clé API d'un service externe détectée dans d'anciens commits du code-source	Difficile	Critique	A
D7	En-têtes de sécurité manquantes pouvant mener à l'exécution de scripts sur le navigateur client (vulnérabilité XSS)	Difficile	Majeur	A
D8	Divulgation d'informations sensibles dans les en-têtes de réponse	Très Difficile	Important	A

Critère « Type » : A = Application, D = Données, P = Politique de sécurité

Échelle de classification des vulnérabilités

Les vulnérabilités identifiées sont évaluées suivant l'échelle standard de classification des vulnérabilités proposée par l'ANSSI, l'Agence Nationale de la Sécurité des Systèmes d'Information, à destination des Prestataires-Auditeurs de la Sécurité des Systèmes d'Information (PASSI).

Elles sont classées en fonction du risque qu'elles font peser sur le système d'information, c'est-à-dire en fonction de l'impact de la vulnérabilité sur le système d'information et de sa difficulté d'exploitation, et ce qu'elles soient d'origine technique ou organisationnelle

Exploitation :

- **Facile :** exploitation triviale, sans outil particulier ;
- **Modérée :** exploitation nécessitant des techniques simples et des outils publics ;
- **Difficile :** exploitation de vulnérabilités publiques nécessitant des compétences en sécurité des systèmes d'information et le développement d'outils simples ;
- **Très difficile :** exploitation de vulnérabilités non publiées nécessitant une expertise en sécurité des systèmes d'information et le développement d'outils spécifiques et ciblés.

Impact :

- **Mineur :** pas de conséquence directe sur la sécurité du système d'information audité ;
- **Important :** conséquences isolées sur des points précis du système d'information audité ;
- **Majeur :** conséquences restreintes sur une partie du système d'information audité ;
- **Critique :** conséquences généralisées sur l'ensemble du système d'information audité.

Risque résultant :

- **Mineur :** faible risque pouvant nécessiter une correction ;
- **Important :** risque modéré nécessitant une correction à moyen terme ;
- **Majeur :** risque majeur nécessitant une correction à court terme ;
- **Critique :** risque critique nécessitant une correction immédiate ou un arrêt immédiat.

↓ Impact Exploit. →	Très difficile	Difficile	Modérée	Facile
Mineur	Mineur	Mineur	Important	Majeur
Important	Mineur	Important	Important	Majeur
Majeur	Important	Majeur	Majeur	Critique
Critique	Important	Majeur	Critique	Critique